
INFORMATION SECURITY POLICY

Document ID: POL-SEC-002 Version: v3.0 Effective Date: February 1, 2024 Review Date: February 1, 2025 Policy Owner: Chief Information Security Officer (CISO) Approval Authority: Executive Leadership Team Classification: Internal Use Only

1. PURPOSE

This policy establishes Acme Corporation's commitment to protecting its information assets and defines the organizational requirements for information security, including security monitoring, incident detection, incident response, and event evaluation. This policy provides the framework within which all information security programs and supporting standards operate.

2. SCOPE

This policy applies to all Acme Corporation personnel, contractors, and third-party service providers. It covers all information systems, networks, endpoints, cloud environments, and data under Acme Corporation's stewardship, regardless of the technology platform or physical location.

3. SECURITY OBJECTIVES

Acme Corporation is committed to maintaining the confidentiality, integrity, and availability of its information assets. The organization's security program is designed to:

- Protect customer and employee data from unauthorized access or disclosure
- Maintain continuous availability of critical business systems
- Detect and respond to security incidents in a timely and effective manner
- Comply with applicable legal, regulatory, and contractual obligations
- Continuously improve the security posture through risk-driven investment

4. SECURITY MONITORING AND ANOMALY DETECTION (CC7.2)

Acme Corporation maintains a continuous security monitoring program to detect threats, anomalies, and operational errors that could adversely affect system availability, integrity, or confidentiality.

4.1 Detection Tools and Coverage

- (a) Security Information and Event Management (SIEM): A centralized SIEM platform ingests and correlates log data from endpoints, servers, network devices, cloud environments, and applications. Detection rules are tuned to identify patterns consistent with malicious activity, misuse, and operational errors.
- (b) Endpoint Detection and Response (EDR): EDR tooling is deployed on all corporate-managed endpoints to provide real-time behavioral monitoring, automated threat containment, and forensic data collection.

- (c) Network Monitoring: Intrusion detection systems (IDS) and network traffic analysis tools monitor east-west and north-south network flows for anomalous communication patterns, lateral movement, and data exfiltration indicators.
- (d) Cloud Security Posture Management (CSPM): Automated tooling monitors cloud environment configurations against security benchmarks and alerts on deviations, including unauthorized API calls, misconfigured storage buckets, and anomalous IAM activity.

4.2 Performance Benchmarks and Alerting

Detection rules include baseline behavioral thresholds for user authentication patterns, data transfer volumes, and privileged command execution. Deviations exceeding defined thresholds generate alerts routed to the Security Operations Center (SOC) for investigation. Mean time to detect (MTTD) targets are reviewed quarterly against operational data.

4.3 Anomaly Classification

Alerts generated by monitoring tools are triaged by SOC analysts and classified as incidents, scheduled reviews, or false positives. Classification criteria and escalation thresholds are documented in the Security Operations Runbook.

5. SECURITY EVENT EVALUATION (CC7.3)

Acme Corporation employs a structured process for evaluating security events to determine whether they constitute security incidents and, if so, to ensure appropriate response actions are taken.

5.1 Event Triage and Incident Determination

All security alerts are assigned to a SOC analyst for initial triage within the defined response time objective based on alert severity. The analyst evaluates each event against documented criteria to determine:

- Whether the event represents a genuine security incident or a false positive
- The nature of the potential threat (e.g., external intrusion, insider threat, malware, accidental exposure)
- Whether the event constitutes a data breach under applicable legal definitions

5.2 Root Cause Analysis

For confirmed security incidents, a root cause analysis is completed to identify the underlying vulnerability or control failure that permitted the incident to occur. Root cause findings are documented in the incident record and assigned to the responsible system or process owner for remediation.

5.3 Impact Assessment

The incident response team assesses the impact of each security incident across three dimensions:

- Availability: Was system uptime or user access affected?
- Confidentiality: Was sensitive data accessed or disclosed without authorization?
- Integrity: Were system configurations, code, or data modified without

authorization?

Impact ratings of High or Critical trigger escalation to the CISO and relevant business unit leadership within four (4) hours of classification.

5.4 Reporting

Security incident findings are reported to appropriate personnel as follows:

- All confirmed incidents: documented in the incident tracking system
- High/Critical incidents: notified to CISO and legal counsel within 4 hours
- Potential breaches: reported to the legal and compliance team for regulatory

notification assessment within 24 hours

- Post-incident review reports: distributed to executive leadership within 30 days of incident closure

6. INCIDENT RESPONSE (CC7.2)

6.1 Incident Classification

Security incidents are classified by severity to prioritize response resources:

- Critical: Active threat to production systems; potential for significant data loss or extended outage. Immediate response required; incident commander assigned.
- High: Confirmed unauthorized access or malware activity; limited but material impact. Response within one (1) hour; senior analyst assigned.
- Medium: Suspected policy violation or anomalous activity requiring investigation. Response within four (4) hours.
- Low: Informational events requiring documentation but no immediate action. Addressed within five (5) business days.

6.2 Response Procedures

The incident response lifecycle follows a structured approach:

- (a) Preparation: Incident response playbooks are maintained for common threat scenarios. Response team members are trained on their roles and the playbooks are tested through tabletop exercises at least annually.
- (b) Identification: SOC analysts document the initial event indicators, affected systems, and observed behaviors that led to incident classification.
- (c) Containment: The incident response team isolates affected systems from the network to prevent further damage. Short-term containment (e.g., account lockout, network block) is applied immediately; long-term containment is planned based on forensic findings.
- (d) Eradication: Malicious artifacts, unauthorized accounts, and vulnerable configurations are removed from affected systems. Patch or remediation activities are tracked to completion.
- (e) Recovery: Affected systems are restored from verified clean backups or rebuilt from approved baselines. Return to production requires sign-off from the incident commander and

relevant system owner.

- (f) Post-Incident Review: Within 30 days of incident closure, a lessons learned review is conducted to identify control improvements and update playbooks.

7. ACCESS CONTROLS IN THE SECURITY CONTEXT (CC6.1, CC6.2)

Effective information security depends in part on appropriate controls over access to security-sensitive systems, including the SIEM, EDR console, and incident tracking platform. Access to these tools is restricted to authorized Security Operations and Information Security personnel. Provisioning of access to security tooling follows the same request-and-approval workflow used for other sensitive systems, requiring manager authorization and a documented business need. Periodic access reviews are conducted to validate the ongoing appropriateness of access to security platforms.

8. RESPONSIBILITIES

- CISO: Owns the information security program; escalation point for Critical and High incidents; approves exception requests.
- Security Operations Center: Operates monitoring tools; performs event triage and incident response; maintains detection rules and runbooks.
- IT and Engineering Teams: Implement technical controls; support containment and recovery activities; remediate identified vulnerabilities.
- Legal and Compliance: Advises on breach notification obligations; manages regulatory reporting.
- All Personnel: Report suspected security incidents to the SOC promptly; comply with security requirements.

9. RELATED DOCUMENTS

- Incident Response Plan (PLAN-SEC-001)
- Security Operations Runbook (RBK-SEC-002)
- Vulnerability Management Policy (POL-SEC-006)
- Data Classification and Handling Policy (POL-SEC-002)
- Business Continuity Plan (PLAN-BC-001)

REVISION HISTORY

Version	Date	Author	Description
v1.0	2021-06-01	CISO	Initial release
v2.0	2022-09-15	CISO	Added SIEM and EDR requirements; revised incident classification tiers
v3.0	2024-02-01	CISO	Expanded event evaluation and root cause analysis requirements; added CSPM coverage
